Continuous Assessment - 1

Colonial Pipeline Ransomware Attack (May 2021)

Team Members:

1) Karnishwar R – 20086868

2) Anandha Krishnan S – 20055947

3) Sanu Mathew – 20075856

Module Title and Code - ORGANISATIONAL AND SOCIETAL CYBERSECURITY (B9CY106)

Module Instructor - Alexander Victor

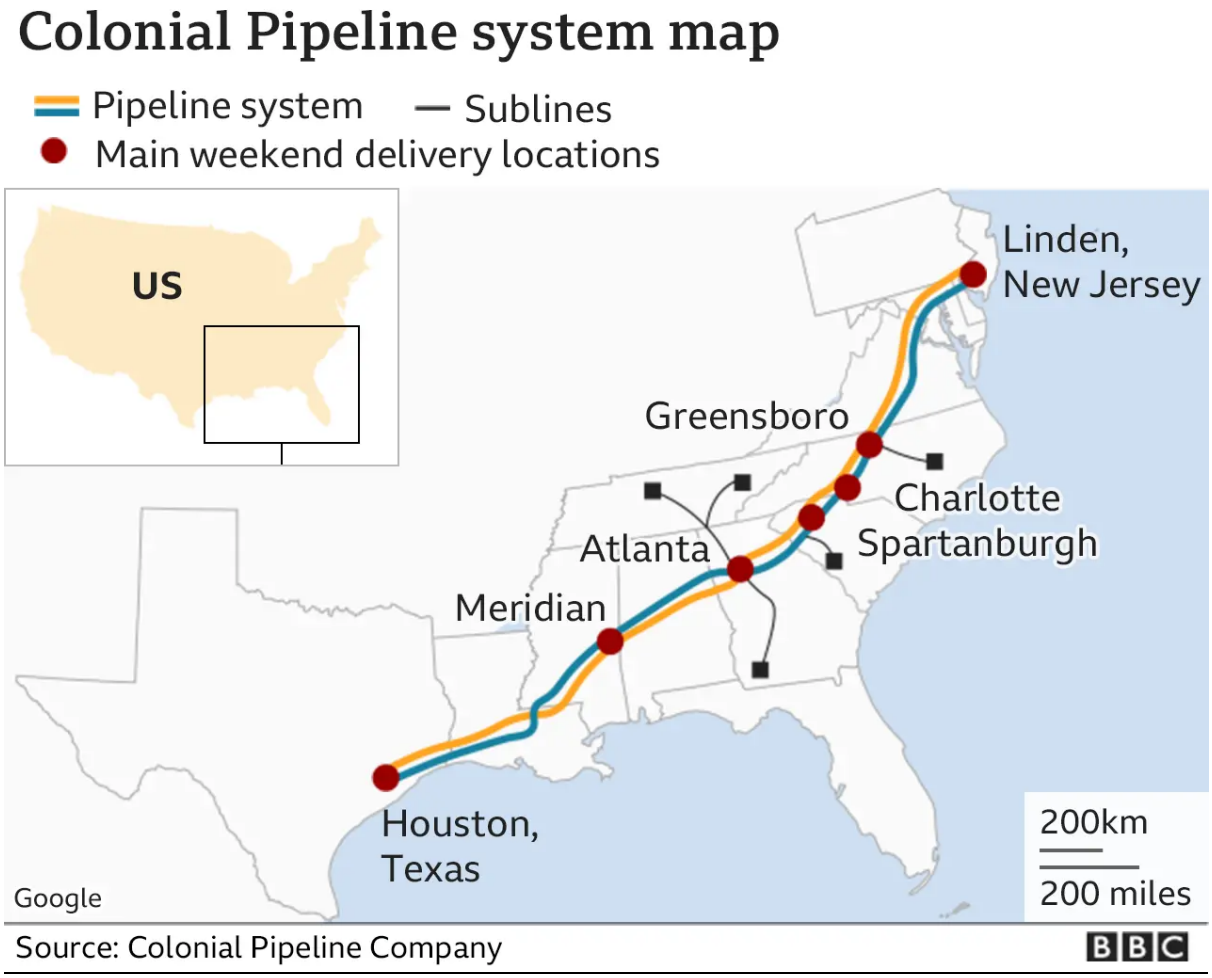
Submission date - 09-02-2026

Total words - 2085

TABLE OF CONTENTS:

S.NO	TOPIC	PAGE NO.
1	Introduction	3
2	Technical and Systematic Attack Analysis	4
2.1	Attack Surface and Initial Access	5
2.2	Attack Chain Reconstruction	5
2.3	Vulnerabilities Exploited	6
2.4	Detection and Response Weakness	7
2.5	MITRE ATTACK x Colonial Pipeline Attack	7
3	Societal and Economic Impact	10
4	Simulation and Post-incident Analysis	11
5	Recommendations	12
6	Attack Details	13
7	Conclusion	14
8	Individual Contribution	14
9	References	15

1. Introduction:

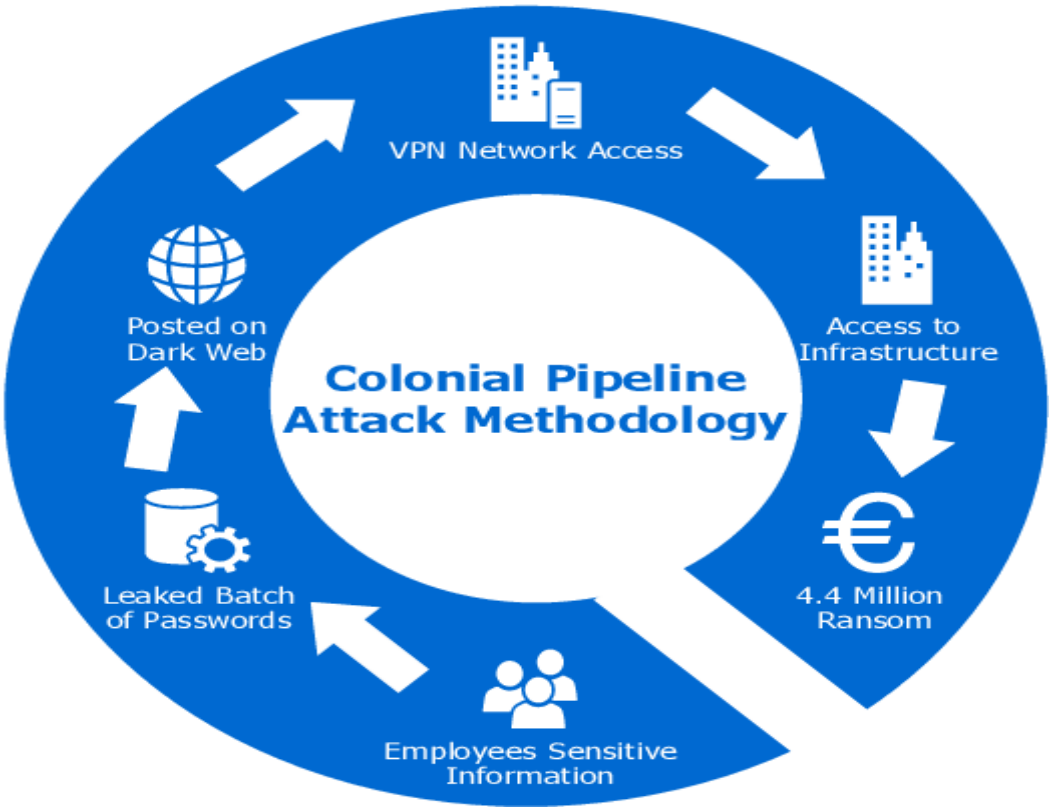


[IMAGE 1 - Colonial Pipeline network supplying fuel across the U.S. East Coast.]

- Infrastructure organizations have become increasingly attractive for cybercriminals due to their important role in maintaining economic stability and public welfare.
- This report examines about the ransomware attack that took place in the **Colonial Pipeline Company.**
- **Colonial Pipeline Company** is the largest refined fuel pipeline operator in the US, responsible for transporting approximately 45% of the of the East Coast's petrol, diesel, and jet fuel through a network spanning over 5,500 miles.
- In May 2021, the organization suffered a ransomware attack that disrupted its IT systems, which lead to shutdown of pipeline operations.

- **The attack was carried out by an Easter European hacker group called DarkSide, who nearly extorted 100GB of company data and demanded a ransom of 75 Bitcoins nearly valued at $4.4 million.**
- This shutdown lead widespread fuel shortages, panic buying of fuel, fuel price increases and substantial economic losses across multiple states.
- This incident demonstrated that how even simple cyber-attacks can have real-world consequences when critical infrastructure is affected.
- The main weakness in this incident was
    - Identity security
    - Network Protection
    - Organizational preparedness, and
    - Lack of employee training

2. Technical and Systematic Attack Analysis:



[IMAGE 2 – COLLONIAL PIPELINE ATTACK METHODOLOGY]

2.1 Attack Surface and Initial Access:

- The initial compromise of **Colonial Pipeline Company** was from the weakness in the remote access infrastructure.
- Like other large enterprises, the pipeline company relied solely on VPN services to allow employees and contractors to access internal systems remotely.
- Eventhough, VPN services are essential for operational flexibility, they also increase the external attack surface by exposing authentication portals to the public internet making it easy for the attackers to get the login details.
- Attackers did not hack anything but were able to get valid login details with old employee VPN accounts.
- Public reports suggest that the password was likely to be reused or was exposed through breaches and password was found in the dark web, which made it easy for attackers to gain access without using complex techniques.
- Another flaw was , the compromised account was not protected with Multi Factor Authentication which made it even more easy for the attackers to gain direct access to the organizations IT network.
- The attackers were logged in as legitimate employee.
- Because the login attempt was valid, already implemented security measures did not trigger any alerts.

2.2 Attack Chain Reconstruction:

- Following successful access to the organization's IT environment, the attackers were able to interact with the internal resources of the organization.
- The attackers performed reconnaissance activities, including identifying accessible servers, shared drives and administrative systems.
- After exploring the network , the attackers moved to other computers to take control of more systems.
- They gained higher permissions and used the internal network to access more servers and sensitive data

- The attackers were easily able to move between systems because of the lack of strict network segmentation in the organizations infrastructure.
- This flat architecture allowed the attack to spread easily and made the damage worse.
- Before deploying ransomware, the attackers exported approximately 100GB of company's data.
- The attackers used **Double extortion,** where stolen data is used as a leverage to pressure victims into paying ransom even if backups are available.
- The extraction process involved staging files internally and transferring them to an external infrastructure managed by the attackers.
- Finally, the attackers ran ransomware, they encrypted the files and systems stopped working.
- Eventhough the machines that control the pipeline like pumps, valves and sensors were not hacked, the systems that track the logistics part like fuel flow, payments, scheduling and monitoring were down
- This lead for the pipeline to be shut down immediately as it was not safe.
- This attack closely correspond with the MITRE ATTACK framework. Which also includes account abuse, lateral movement, data extraction and data encryption for demanding ransom.

2.3 Vulnerabilities Exploited:

- The success of this attack was mainly due to the organization's basic security mistakes.
- The most significant vulnerability was the absence of Multi Factor Authentication on VPN accounts.
- Due to the lack of MFA, a single stolen password was enough to gain access into the company's network.
- This highlights the failure of the company to manage user accounts properly, in a highly sensitive environment.
- Additional vulnerabilities were
    - Weak passwords,
    - Reused passwords
- Weak logging and monitoring also contributed to late detection.

2.4 Detection and Response Weakness:

- Beyond weak security, the company's monitoring and response were also weak, which lead to more damage.
- The system did not Red Flag the VPN login since it was a legacy VPN credential.
- The organization's response was largely reactive.
- They only made preventive measures after the damage took place.
- Since, they did not know about the severity of the attack, everything was shutdown to be safe.
- Good planning strategies could have reduced the damage like isolating only the affected systems from the network.
- Using the NIST Cybersecurity Framework as a benchmark, gaps was particularly evident in detect and respond functions.

2.5 MITRE ATTACK x Colonial Pipeline Attack:

- A better insight into who the attacker had led us to the MITRE ATT&CK framework.
- It contains comprehensive list of common tactics and techniques used by attackers in cyber-attacks.
- It is simpler to place each step of the Colonial Pipeline attack on the parallel to MITRE technique, which is why one can visually observe how the attackers accessed the network, traveled within it, stolen data, and, eventually, applied ransomware.

Phase	Technique Used	Explanation
Initial Access	Valid Accounts (T1078)	Attackers logged in using stolen VPN credentials.
Persistence	Remote Services (T1021)	VPN access allowed continued remote entry into network.
Discovery	Network Discovery (T1046)	Attackers exploited internal systems to identify servers and weak points.
Lateral Movement	Remote Services (T1021)	Movement between multiple systems sue to weak network segmentation.
Exfiltration	Data Staging (T1074)	Approximately 100GB of data was exported.
Impact	Data Encryption For Impact (T1486)	Ransomware encrypted files and disrupted business operations.

[IMAGE 3 – CYBER KILL CHAIN VS. MITRE ATTACK]

3. Societal and Economic Impact:

[IMAGE 4 – SOCIETAL IMPACT]

- The **Colonial Pipeline attack** affected not only the organization but also the public because the company operates critical national infrastructure.
- **Colonial Pipeline** Supplies approximately 45% of the fuel consumed along the US East Coast.
- Any disruption directly affects millions of people.
- After the Ransomware was detected, the company shut down its pipeline operations for approximately 5 days, causing interruption in fuel distribution.
- Multiple states experienced fuel shortages and gas stations ran out of fuel supply.
- People responded with panic buying, long queues in fuel stations which even more worsened the shortage.
- Fuel prices increased in many regions.
- Airlines and transportation services were also disrupted due to limited availability of jet fuel and diesel supplies.
- The organization paid approximately **$4.4 million (75 BTC)** in ransom to the attackers in addition to costs with system recovery, investigations and operational downtime.
- Losses including reputational damage, reduced customer trust and business downtime exceeded the ransom payment itself.
- As a result of this attack, government authorities introduced stricter cybersecurity regulations and increased supervision in pipeline and other sectors related with national infrastructure.
- Overall, this breach highlight that how a simple password theft intrusion can lead to economic disruption.

4. Simulation and Post-incident Analysis:

```
==================================================
COLONIAL PIPELINE RANSOMWARE BREACH SIMULATION
==================================================
Attack Date: May 07, 2021
Threat Actor: DarkSide
Data Exfiltrated: ~100 GB
Ransom Paid: 75 BTC (~$4.4M)
Recovered by authorities: 64 BTC (~$2.3M)
Operations Shutdown: ~5 days

Generated 38 records
Total breach size: 100.11 GB

====== IMPACT SUMMARY ======
Total people/systems affected: 89,492
Total records: 38

Data Type Distribution:
Customer: 4 records
Financial: 9 records
IT Systems: 10 records
Employee: 6 records
Operational: 9 records

Risk Distribution:
CRITICAL: 10 records
HIGH: 8 records
MEDIUM: 8 records
LOW: 12 records

Top 5 priority records:
ID 19 | Customer | Risk: CRITICAL
ID 17 | Financial | Risk: HIGH
ID 33 | Customer | Risk: HIGH
ID 20 | Financial | Risk: CRITICAL
ID 36 | Financial | Risk: CRITICAL
```

[IMAGE 5 - Output from the Python-based breach simulation tool developed to estimate the impact and prioritize response actions.]

- We created a post-incident breach simulation tool to model the potential consequences of the **Colonial Pipeline Ransomware attack.**
- We used a python-based breach analysis tool to simulate approximately 100GB of extracted data.
- We generated synthetic breach records representing operational, financial and employee information likely to be affected in a critical infrastructure environment.
- We categorized each record based on sensitivity and potential business impact.
- We applied risk classification logic to group compromised data into critical, high, medium and low-level risks.

- We calculated the total volume of compromised data and the number of affected records to estimate the overall severity of the breach.
- We counted how many systems and users were affected to estimate how serious the disruption was.
- We recorded how long the breach went undetected to see how delays could worsen the overall impact.
- We ranked the highest-risk assets first so that recovery could focus on the most critical systems.
- We generated summary statistics and outputs to provide a quantitative assessment of business and operational impact.
- This simulation provided a quantitative estimate of potential losses and helped visualize how delayed detection and poor prioritization could increase the overall impact of a ransomware incident. It also demonstrated how data-driven analysis can support faster and more effective incident response planning.

5. Recommendations:

- **Colonial Pipeline** incident demonstrates that a simplistic security measures should be established as a base and more sophisticated cybersecurity tools should follow.
- **MFA** should be enables on all remote accounts to prevent use others from logging in just with the username and password.
- Stricter password policies and frequent account verification must be done to reduce the likelihood of creating a duplicate password and sharing an account with old passwords.
- Network segmentation must be improved, since most companies depend on computer for most of its operations, reducing attack propagation.
- Constant tracking and real-time notifications must be enabled to identify suspicious logins.
- Security audits and risk checks must be conducted regularly to identify weak points and prevent them immediately.

- Incident response team must be trained through simulations and drills to make sure they detect and immediately respond to an attack.
- Back-up and recovery measures must be enhanced so that even in an attack important data can be reconfigured and protected.
- Human errors can be reduced by staff training and awareness programs.
- Business continuity planning should include cybersecurity so that even in an attack important process continues safely.

6. Attack Details:

Attack Dates	Explanation
April 29, 2021	**Hackers got the initial access to the details from Dark Web leaks.**
May 6, 2021	**Eastern European Attackers from hacking group DarkSide stole approximately 100GB of company's data.**
May 7, 2021	**Ransomware was deployed across the company's IT systems, data was encrypted and operations were disrupted.**
May 7, 2021	**Operations were shut down by the organization after they detected the attack.**
May 9, 2021	**Regional emergency was declared by U.S. government to help manage fuel supply disruptions caused by the outage.**
May 12, 2021	**Operations were restored approximately after 5 days from shutdown.**
June 7, 2021	**U.S. Department of Justice reported it had recovered most of the ransom payment in Bitcoin. (approx. 64 BTC out of 75 BTC) nearly $2.3 million**

7. Conclusion:

The **Colonial Pipeline Ransomware** incident demonstrates the fact that a rightful hack is a massive issue when a critical infrastructure is targeted. It began in **April 2021** when hackers stole unauthorised access to VPN. On **May 6,** they stole approximately **100GB** of data and put ransomware on it, which caused the company to stop operations nearly five days. Since **Colonial Pipeline** delivers nearly 45% of fuel demand on the **U.S. East Coast,** the closures lead to shortages etc. The company approximately paid **$4.4 million (75 BTC), mostly in Bitcoin** as ransom. So, finally to prevent such a large issue in future, it is important to have good security when logging in, have constant supervision and be prepared to be attacked.

8. Individual Contribution:

8.1 Karnishwar R:

- Developed the Python-based breach simulation and used it to calculate the breach impact and risk levels.
- Supported with making report.

8.2 Anandha Krishnan S:

- Prepared the main report.
- Assisted in working with the simulation tool.

8.3 Sanu Mathew:

- Prepared the PowerPoint presentation.

9. References:

1) What is the Colonial Pipeline Hack? A Timeline of Events by **Eye on Tech - Link (YouTube Video)**

2) How a cyber-attack crippled the Colonial Pipeline by **CNET - link (YouTube Video)**

3) The Attack on Colonial Pipeline: What We've Learned & What We've Done Over the Past Two Years by **America's Cyber Defence Agency (CISA – CYBERSECURITY & INFRASTRUCTURE SECURITY AGENCY) - Link**

4) Cyber Case Study: Colonial Pipeline Ransomware Attack by **CoverLink Insurance - Ohio Insurance Agency - Link**

5) Department of Justice Seizes $2.3 Million in Cryptocurrency Paid to the Ransomware Extortionists Darkside by **U.S. DEPARTMENT OF JUSTICE - Link**